

Security Scan Report

Target: http://127.0.0.1:5001

Scan Date: July 23, 2026 at 14:34 UTC

Scan ID: 89079db7-e9a1-495b-a6df-280bacd1a752

0 CRITICAL

4 HIGH

2 MEDIUM

3 LOW

Executive Summary

Security scan of 'http://127.0.0.1:5001' identified 18 raw findings, reduced to 9 unique issues after deduplication. ■ 4 HIGH-severity issue(s) should be prioritized for remediation within the next 48 hours. 2 MEDIUM-priority issue(s) should be addressed in the current development sprint. 3 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	18
After Deduplication	9
Critical Findings	0
High Findings	4
Medium Findings	2
Low Findings	3
Scan Duration	11.0s

Detailed Findings

[HIGH] #1: Missing Auth in admin:0

Risk Score	0.6839
Affected Location	http://127.0.0.1:5001/admin:0
Vulnerability Type	MISSING_AUTH
CWE ID	CWE-306
Detected By	url-scanner

Explanation

Missing or broken authentication allows unauthorized users to access protected functionality or data without proper identity verification.

Code or HTTP Excerpt

```
1 | GET /admin → HTTP 200
2 | Content-Length: 1341 bytes
3 | Preview: <!DOCTYPE html>
4 | <html>
5 | <head>
6 |   <title>VulnApp - Admin</title>
7 | </head>
8 | <body style="font-family: Arial, sans-serif; max-width: 900px; margin: 0 auto
```

Business Impact

Unauthorized users could access sensitive data or perform privileged operations without any authentication.

Fix Recommendation

Rule-based recommendation: Ensure all sensitive endpoints require authentication. Use established authentication frameworks and middleware. Implement proper session management with secure cookie flags.

LLM recommendation: Ensure all sensitive endpoints require authentication. Use established authentication frameworks and middleware. Implement proper session management with secure cookie flags.

[HIGH] #2: Information Disclosure in .env:0

Risk Score	0.6063
Affected Location	http://127.0.0.1:5001/.env:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /.env → HTTP 200
2 | Content-Length: 66 bytes
3 | Preview: DB_PASSWORD=admin123
4 | SECRET_KEY=mysecretkey
5 | API_KEY=sk-1234567890
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[HIGH] #3: Information Disclosure in backup.sql:0

Risk Score	0.6063
Affected Location	http://127.0.0.1:5001/backup.sql:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-530
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /backup.sql → HTTP 200
2 | Content-Length: 138 bytes
3 | Preview: -- MySQL dump
4 | CREATE TABLE users (id INT, username VARCHAR(50), password VARCHAR(50));
5 | INSERT INTO users VALUES (1, 'admin', 'admin123');
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[HIGH] #4: Insecure Transport in 127.0.0.1:5001:0

Risk Score	0.5700
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	INSECURE_TRANSPORT
CWE ID	CWE-319
Detected By	url-scanner

Explanation
The site is served over unencrypted HTTP. All data transmitted between the user and the server — including passwords, session tokens, and personal data — can be intercepted by attackers.

Business Impact
User credentials, personal data, and session tokens can be intercepted by anyone on the same network, leading to account takeover and data theft.

Fix Recommendation
Rule-based recommendation: Enable HTTPS with a valid TLS certificate (e.g. via Let's Encrypt). Redirect all HTTP traffic to HTTPS. Add the Strict-Transport-Security header to prevent future HTTP connections.

LLM recommendation: Enable HTTPS with a valid TLS certificate (e.g. via Let's Encrypt). Redirect all HTTP traffic to HTTPS. Add the Strict-Transport-Security header to prevent future HTTP connections.

[MEDIUM] #5: Information Disclosure in config:0

Risk Score	0.4462
Affected Location	http://127.0.0.1:5001/.git/config:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-538
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /.git/config → HTTP 200
2 | Content-Length: 115 bytes
3 | Preview: [core]
4 | █repositoryformatversion = 0
5 | █bare = false
6 | [remote "origin"]
7 | █url = https://github.com/user/secret-repo.git
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[MEDIUM] #6: Information Disclosure in robots.txt:0

Risk Score	0.4220
Affected Location	http://127.0.0.1:5001/robots.txt:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /robots.txt → HTTP 200
2 | Content-Length: 65 bytes
3 | Preview: User-agent: *
4 | Disallow: /admin
5 | Disallow: /backup
6 | Disallow: /.env
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #7: Insecure Cookie in 127.0.0.1:5001:0

Risk Score	0.3920
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	INSECURE_COOKIE
CWE ID	CWE-1004
Detected By	url-scanner

Explanation

One or more cookies are missing important security flags. Without Secure, HttpOnly, and SameSite attributes, cookies may be exposed to theft or misuse.

Code or HTTP Excerpt

```
1 | Set-Cookie: session_id=abc123; Path=/
```

Business Impact

Session cookies without proper flags can be stolen via XSS or transmitted over insecure connections, enabling attackers to hijack user sessions.

Fix Recommendation

Rule-based recommendation: Set the Secure flag on all cookies served over HTTPS. Set HttpOnly on session cookies to prevent JavaScript access. Set SameSite=Lax or SameSite=Strict to mitigate CSRF attacks.

LLM recommendation: Set the Secure flag on all cookies served over HTTPS. Set HttpOnly on session cookies to prevent JavaScript access. Set SameSite=Lax or SameSite=Strict to mitigate CSRF attacks.

[LOW] #8: Clickjacking in 127.0.0.1:5001:0

Risk Score	0.3589
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	CLICKJACKING
CWE ID	CWE-1021
Detected By	url-scanner

Explanation

The application does not set X-Frame-Options or CSP frame-ancestors, allowing it to be embedded in an iframe on a malicious site. Attackers can overlay invisible UI elements to trick users.

Code or HTTP Excerpt

```
1 | Response headers: X-Frame-Options = (not set)
```

Business Impact

Users could be tricked into performing unintended actions such as transferring funds or changing account settings.

Fix Recommendation

Rule-based recommendation: Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content-Security-Policy with the frame-ancestors directive: frame-ancestors 'self'.

LLM recommendation: Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content-Security-Policy with the frame-ancestors directive: frame-ancestors 'self'.

[LOW] #9: Information Disclosure in 127.0.0.1:5001:0

Risk Score	0.1960
------------	--------

Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | X-Powered-By: Flask/2.0.1 Python/3.10.0
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

Appendix

Deduplication Statistics

Total raw findings: 18 | After deduplication: 9 | Reduction: 50%

Scan Metadata

Scan ID	89079db7-e9a1-495b-a6df-280bacd1a752
Target	http://127.0.0.1:5001
Timestamp	2026-07-23T14:34:10.652241+00:00
Duration	11.0s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "88cc8068-537b-4585-8d1b-5437ea5f4b27",
    "title": "Missing Auth in admin:0",
    "file": "http://127.0.0.1:5001/admin",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "MISSING_AUTH",
    "description": "Admin panel may be accessible without proper authentication.",
    "rule_id": "sensitive-path-admin",
    "confidence": 0.85,
    "cwe_id": "CWE-306",
    "cvss_score": null,
    "code_snippet": "GET /admin \u2192 HTTP 200\nContent-Length: 1341 bytes\nPreview: <!DOCTYPE html>\n<html>\n</html>\n",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.6839,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "Missing or broken authentication allows unauthorized users to access protected functionality.",
    "fix_suggestion": "Ensure all sensitive endpoints require authentication. Use established authentication mechanisms.",
    "business_impact": "Unauthorized users could access sensitive data or perform privileged operations without proper authorization.",
    "raw": {
      "url": "http://127.0.0.1:5001/admin",
      "status": 200,
      "path": "/admin"
    }
  },
  {
    "id": "e71e5b67-e391-439b-a825-de9704465846",
    "title": "Information Disclosure in .env:0",
    "file": "http://127.0.0.1:5001/.env",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Sensitive information (API keys, database credentials) is exposed in the .env file.",
    "rule_id": "sensitive-file-disclosure",
    "confidence": 0.9,
    "cwe_id": "CWE-264",
    "cvss_score": 5.0,
    "code_snippet": ".env\nAPI_KEY=sk-1234567890\nDB_PASSWORD=secret123\n",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.75,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "Sensitive information (API keys, database credentials) is exposed in the .env file.",
    "fix_suggestion": "Remove sensitive information from the .env file and use environment variables or secure storage.",
    "business_impact": "Sensitive information (API keys, database credentials) is exposed, potentially leading to data breaches or unauthorized access.",
    "raw": {
      "url": "http://127.0.0.1:5001/.env",
      "status": 200,
      "path": "/.env"
    }
  }
]
```

```

    "description": "Exposed .env file \u2014 may contain secrets, API keys, and database credentials.",
    "rule_id": "sensitive-path-.env",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /.env \u2192 HTTP 200\nContent-Length: 66 bytes\nPreview: DB_PASSWORD=admin123\nSE",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.6063,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
    "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
    "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific so",
    "raw": {
      "url": "http://127.0.0.1:5001/.env",
      "status": 200,
      "path": "/.env"
    }
  },
  {
    "id": "1e860739-3649-433b-8fc0-22b4f26a23a6",
    "title": "Information Disclosure in backup.sql:0",
    "file": "http://127.0.0.1:5001/backup.sql",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Database backup file is publicly accessible \u2014 critical data exposure.",
    "rule_id": "sensitive-path-backup.sql",
    "confidence": 0.85,
    "cwe_id": "CWE-530",
    "cvss_score": null,
    "code_snippet": "GET /backup.sql \u2192 HTTP 200\nContent-Length: 138 bytes\nPreview: -- MySQL dump\nCRE",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.6063,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
    "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
    "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific so",
    "raw": {
      "url": "http://127.0.0.1:5001/backup.sql",
      "status": 200,
      "path": "/backup.sql"
    }
  },
  {
    "id": "be983ad2-60f7-49e7-bedc-d79565ab6f32",
    "title": "Insecure Transport in 127.0.0.1:5001:0",
    "file": "http://127.0.0.1:5001",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INSECURE_TRANSPORT",
    "description": "Site is served over plain HTTP. All traffic including credentials and session tokens is",
    "rule_id": null,
    "confidence": 1.0,
    "cwe_id": "CWE-319",
    "cvss_score": null,
    "code_snippet": null,
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.57,
    "risk_category": "HIGH",

```

```
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The site is served over unencrypted HTTP. All data transmitted between the user and
"fix_suggestion": "Enable HTTPS with a valid TLS certificate (e.g. via Let's Encrypt). Redirect all HTTP
"business_impact": "User credentials, personal data, and session tokens can be intercepted by anyone on
"raw": {
  "url": "http://127.0.0.1:5001",
  "check": "insecure_transport"
}
},
{
  "id": "e0323543-77ef-4f5d-8ccc-edc69b8f9260",
  "title": "Information Disclosure in config:0",
  "file": "http://127.0.0.1:5001/.git/config",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Exposed .git directory \u2014 source code and commit history are publicly accessible.",
  "rule_id": "sensitive-path-.git-config",
  "confidence": 0.85,
  "cwe_id": "CWE-538",
  "cvss_score": null,
  "code_snippet": "GET /.git/config \u2192 HTTP 200\nContent-Length: 115 bytes\nPreview: [core]\n\treposit
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.4462,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof
  "raw": {
    "url": "http://127.0.0.1:5001/.git/config",
    "status": 200,
    "path": "/.git/config"
  }
},
{
  "id": "bee4f3e1-0375-426c-b101-1b0547ed1a81",
  "title": "Information Disclosure in robots.txt:0",
  "file": "http://127.0.0.1:5001/robots.txt",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "robots.txt may reveal hidden paths and sensitive directories.",
  "rule_id": "sensitive-path-robots.txt",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /robots.txt \u2192 HTTP 200\nContent-Length: 65 bytes\nPreview: User-agent: *\nDis
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.422,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof
  "raw": {
    "url": "http://127.0.0.1:5001/robots.txt",
    "status": 200,
    "path": "/robots.txt"
  }
},
{
  }
```

```

    "id": "1753223f-7e49-4d96-bc80-3bc715e2d4f2",
    "title": "Insecure Cookie in 127.0.0.1:5001:0",
    "file": "http://127.0.0.1:5001",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INSECURE_COOKIE",
    "description": "Session cookie 'session_id' is missing the HttpOnly flag. It can be accessed by JavaScript.",
    "rule_id": "cookie-missing-httponly",
    "confidence": 0.9,
    "cwe_id": "CWE-1004",
    "cvss_score": null,
    "code_snippet": "Set-Cookie: session_id=abc123; Path=/",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.392,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "One or more cookies are missing important security flags. Without Secure, HttpOnly, and SameSite, cookies can be stolen via XSS or transmitted over insecure connections.",
    "fix_suggestion": "Set the Secure flag on all cookies served over HTTPS. Set HttpOnly on session cookies. Use SameSite=Strict for all cookies.",
    "business_impact": "Session cookies without proper flags can be stolen via XSS or transmitted over insecure connections, leading to account hijacking.",
    "raw": {
        "url": "http://127.0.0.1:5001",
        "cookie": "session_id"
    }
},
{
    "id": "a5f13ef4-d6b3-4d70-99eb-00c7aaef744d",
    "title": "Clickjacking in 127.0.0.1:5001:0",
    "file": "http://127.0.0.1:5001",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "CLICKJACKING",
    "description": "Missing X-Frame-Options header. The site may be vulnerable to clickjacking attacks where users are tricked into clicking on hidden elements.",
    "rule_id": "header-missing-x-frame-options",
    "confidence": 0.85,
    "cwe_id": "CWE-1021",
    "cvss_score": null,
    "code_snippet": "Response headers: X-Frame-Options = (not set)",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.3589,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The application does not set X-Frame-Options or CSP frame-ancestors, allowing it to be loaded in an iframe, which can be used for clickjacking.",
    "fix_suggestion": "Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content-Security-Policy: frame-ancestors 'self' to restrict framing.",
    "business_impact": "Users could be tricked into performing unintended actions such as transferring funds or changing account details.",
    "raw": {
        "url": "http://127.0.0.1:5001",
        "header": "X-Frame-Options",
        "check": "missing_header"
    }
},
{
    "id": "416f9b22-0b30-4386-8563-6bffa47a4ab0",
    "title": "Information Disclosure in 127.0.0.1:5001:0",
    "file": "http://127.0.0.1:5001",
    "line_start": 0,
    "line_end": null,
    "severity": "LOW",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "X-Powered-By header discloses technology stack: 'Flask/2.0.1 Python/3.10.0'. Remove this header to reduce information leakage.",
    "rule_id": "info-x-powered-by",
    "confidence": 0.9,
    "cwe_id": "CWE-200",
    "cvss_score": null,

```

```
"code_snippet": "X-Powered-By: Flask/2.0.1 Python/3.10.0",
"sources": [
  "url-scanner"
],
"risk_score": 0.196,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
"fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
"business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific software.",
"raw": {
  "url": "http://127.0.0.1:5001",
  "header": "X-Powered-By",
  "value": "Flask/2.0.1 Python/3.10.0"
}
}
```